محاضرة الأسبوع السابع - حوكمة الأمن السيبراني

التطبيق العملي لإدارة المخاطر: بناء سجل المخاطر السيبرانية

إعداد

أ.د. ضياء جاسم كاظم

خارطة طريق المحاضرة

محاور الأسبوع السابع للتدريب العملي على بناء سجل المخاطر

1. الإطار المفاهيمي
ربط النظرية بالدورة العملية لسجل المخاطر وأهميته التشغيلية.

2. هيكلية السجل
تشريح الأعمدة الرئيسية والبيانات الوصفية المطلوبة لكل خطر.

3. التحديد والتحليل
صياغة سيناريوهات التهديد وتطبيق معادلة المخاطر الكمية والنوعية.

4. مصفوفة التقييم
تطوير مصفوفة 5×5لتحديد مستويات الخطر الكامن والمتبقي.

5. معالجة المخاطر
اختيار الضوابط السيبرانية وتعيين مالكي المخاطر وخطط العمل.

6. ورشة عمل حية
تطبيق عملي شامل لبناء 5سيناريوهات واقعية داخل السجل.

ما هو سجل المخاطر السيبرانية؟

الوثيقة الحية المحورية لحوكمة الأمن السيبراني واتخاذ القرار

أداة توثيق مركزية

قاعدة بيانات شاملة تسجل جميع التهديدات والهشاشات والأصول المتأثرة عبر المؤسسة.

بوصلة اتخاذ القرار

تزود الإدارة العليا بالرؤية المباشرة لتوجيه ميزانيات الاستثمار في ضوابط الحماية.

سجل ديناميكي مستمر

وثيقة حية تتطلب التحديث المستمر مع تغير مشهد التهديدات والبيئة التقنية.

"ما لا يمكن قياسه لا يمكن إدارته، وسجل المخاطر هو الأداة الوحيدة التي تحول التهديدات السيبرانية المبهمة إلى أرقام وأولويات عمل واضحة".

—إطار حوكمة NIST SP 800-30

التوافق مع المعايير الدولية

كيف تؤطر المعايير القياسية بناء سجل المخاطر

NIST SP 800-30 Rev. 1

يركز على التحليل الفني لتهديدات نظم المعلومات:

تحديد مصادر التهديد والعوامل المساعدة.

تقييم احتمالية الاستغلال والأثر الفني.

ربط نتائج التقييم بوظيفة Govern في NIST CSF 2.0.

ISO/IEC 27005:2022

يركز على حوكمة أمن المعلومات المؤسسية:

تأسيس السياق وتحديد ملكية الأصول.

تقدير المخاطر بناءً على تأثير الأعمال (BIA).

مطبقة مباشرة لدعم معيار ISO 27001 (البند 6.1.2).

دورة حياة سجل المخاطر

الخطوات الأربع الأساسية للحفاظ على فاعلية السجل

مرحلة 01

التحديد والإدخال

رصد الثغرات والتهديدات وتأطيرها كسيناريوهات خطر معتمدة.

مرحلة 02

التحليل والتقييم

حساب الأثر والاحتمالية لتحديد درجة الخطر الكامن أولياً.

مرحلة 03

المعالجة والتكييف

تطبيق الضوابط وتحديد الخطر المتبقي ومالك الخطر المسند.

مرحلة 04

المراجعة والرقابة

التدقيق الدوري لفعالية الضوابط وتحديث المستويات بانتظام.

الأعمدة الأساسية لسجل المخاطر

المكونات الهيكلية الضرورية لبناء سجل احترافي

1. البيانات التعريفية

- معرف الخطر (Risk ID)
- الأصل المترابط (Asset)
- مالك الخطر (Risk Owner)

2. وصف الخطر

- مصدر التهديد (Threat)
- نقطة الضعف (Vulnerability)
- التأثير التجاري (Impact)

3. التقييم الأول

- الاحتمالية الكامنة (L)
- الأثر الكامن (I)
- الخطر الكامن (Inherent)

4. المعالجة والتعقيب

- الضوابط المقترحة (Controls)
- الخطر المتبقي (Residual)
- تاريخ المراجعة (Review Date)

البيانات الوصفية ومعرفات الخطر

أهمية الترميز وحوكمة ملكية البيانات داخل السجل

نظام الترقيم والتصنيف (Risk ID)

يُوصى بتصنيف المخاطر وفق المجال لسهولة الفلترة والتدقيق:

- RSK-NET-001 (مخاطر الشبكات)
- RSK-IAM-002 (مخاطر الهوية والصلاحيات)
- RSK-APP-003 (مخاطر التطبيقات)
- RSK-SUP-004 (مخاطر سلاسل التوريد)

تحديد مالك الخطر (Risk Owner)

مالك الخطر ليس شخصاً بل موقعاً وظيفياً مسؤولاً عن اتخاذ قرار المعالجة:

- رئيس البنية التحتية :لمخاطر خوادم البيانات.
- مدير تطوير البرمجيات :ثغرات التطبيقات.
- مدير سلاسل التوريد :مخاطر الموردين الجدد.

معادلة الخطر السيبراني العملياتية

النموذج الرياضي القياسي لحساب مستوى الخطر الكامن

الخطر = التهديد × الثغرة × الأثر

Risk = Threat × Vulnerability × Impact

التهديد (Threat)

حدث خارجي أو داخلي قد يتسبب بضرر (مثل: الهجمات، الكوارث، الأخطاء البشرية).

الثغرة (Vulnerability)

نقطة ضعف في الأصول أو الإجراءات تمكّن التهديد من النفاذ والتأثير.

الأثر (Impact)

حجم الضرر المالي، التشغيلي، القانوني، أو السمعة في حال تحقق التهديد.

مقاييس احتمالية حدوث الخطر (Likelihood)

تحديد درجات الاحتمالية وفق سلم 5 درجات معتمد

الدرجة	المستوى	الوصف العملي	معدل التكرار المتوقع
1	شبه نادر (Rare)	قد يحدث فقط في ظروف استثنائية للغاية.	أقل من مرة كل 5 سنوات
2	غير محتمل (Unlikely)	هناك إمكانية للحدوث ولكن المعطيات لا ترجحه.	مرة كل 2 إلى 5 سنوات
3	محتمل (Possible)	قد يحدث في وقت ما بناءً على التاريخ التشغيلي.	مرة واحدة سنوياً
4	مرجح (Likely)	من المتوقع حدوثه في معظم الظروف التشغيلية.	عدة مرات في السنة
5	مؤكد تقريباً (Almost Certain)	يتوقع حدوثه باستمرار وبشكل يومي أو أسبوعي.	يتكرر شهرياً أو أكثر

مقاييس أثر الخطر (Impact Scale)

تحديد مستويات التأثير التشغيلي والمالي والسمعة

الدرجة	مستوى الأثر	الضرر المالي/التشغيلي	تأثير السمعة والامتثال
1	ضئيل (Insignificant)	خسارة مالية لا تذكر، انقطاع الخدمة دقائق.	لا يوجد أثر إعلامي أو تنظيمات.
2	بسيط (Minor)	خسارة مالية محدودة، معالجة داخلية سهلة.	شكاوى عملاء فردية ومحدودة.
3	متوسط (Moderate)	توقف النظام لعدة ساعات، تكاليف معالجة ملحوظة.	تغطية إعلامية محلية بسيطة.
4	كبير (Major)	خسائر مالية كبيرة، توقف الخدمات الأساسية لليوم.	غرامات تنظيمية وضرر سمعة واضح.
5	كارثي (Catastrophic)	تهديد الاستمرارية، توقف أعمال، خسائر ضخمة.	غرامات حادة وفقدان ترخيص العمل.

مصفوفة تقييم المخاطر (Risk Matrix) 5×5

ربط الاحتمالية بالأثر لاستخراج درجة الخطر الإجمالية

الاحتمالية \ الأثر	1 - ضئيل	2 - بسيط	3 - متوسط	4 - كبير	5 - كارثي
5 - مؤكد	5 (متوسط)	10 (عالي)	15 (حرج)	20 (حرج جداً)	25 (أقصى)
4 - مرجح	4 (منخفض)	8 (متوسط)	12 (عالي)	16 (حرج)	20 (حرج جداً)
3 - محتمل	3 (منخفض)	6 (متوسط)	9 (متوسط)	12 (عالي)	15 (حرج)
2 - غير محتمل	2 (منخفض)	4 (منخفض)	6 (متوسط)	8 (متوسط)	10 (عالي)
1 - نادر	1 (منخفض)	2 (منخفض)	3 (منخفض)	4 (منخفض)	5 (متوسط)

الخطر الكامن مقابل الخطر المتبقي

كيف تقلل الضوابط الأمنية من مستويات الخطر

الخطر الكامن (Inherent Risk)

مستوى الخطر الأصلي الموجود في البيئة التشغيلية **قبل تطبيق أو احتساب أي ضوابط أمنية** أو إجراءات وقائية.

←

الضوابط الأمنية (Controls)

السياسات، البرمجيات، والتقنيات المطورة وتقليص الثغرات (مثل: الجدران النارية، التشفير، المصادقة الثنائية).

←

الخطر المتبقي (Residual Risk)

مستوى الخطر المتبقي القائم **بعد تطبيق الضوابط الأمنية**، وهو المستوى الذي يُعرض على القيادة للقبول.

استراتيجيات معالجة المخاطر (4 Ts)

الخيارات الأربعة القياسية للحوكمة والتعامل مع الخطر

1. التخفيض والمعالجة (Treat / Mitigate)

تطبيق ضوابط أمنية تقنية أو تنظيمية للحد من الاحتمالية أو الأثر (الخيار الأبرز).

2. التجاهل والتجنب (Avoid)

إلغاء النشاط أو إيقاف النظام المسبب للخطر نهائياً لتفادي وقوعه.

3. النقل والمشاركة (Transfer)

تحويل العبء المالي للخطر لأطراف أخرى (مثل: التأمين السيبراني أو عقد المورد).

4. القبول والتحمل (Tolerate / Accept)

قبول الخطر المتبقي كما هو بشرط وقوعه ضمن حدود تحمل المخاطر المعتمدة (Appetite).

الورشة التطبيقية

تعبئة سجل المخاطر لسيناريوهات واقعية

سنقوم الآن بتحليل وتفريغ 5حالات دراسية واقعية لمؤسسات حديثة داخل جدول سجل المخاطر، وتتبع التحول من الخطر الكامن إلى المتبقي.

سيناريو -1: هجوم برمجيات الفدية (Ransomware)

تحليل خطر تشفير قواعد البيانات التشغيلية عبر البريد الإلكتروني

وصف الحالة

وصول رسالة تصيد أحتيالي لموظف في المالية تحوي ملفاً خبيثاً، أدى لتشفير خادم الخزينة وتوقف العمليات.

التهديد والثغرة

تصيد احتيالي + غياب وعي الموظفين وتحديثات مضاد الفيروسات

الخطر الكامن

احتمالية (4) × أثر (5) = 20 (حرج جداً)

الخطر المتبقي (بعد الضوابط)

احتمالية (2) × أثر (3) = 6 (متوسط)

تفريغ سيناريو-1 في سجل المخاطر

تنسيق البيانات الخاصة بهجوم الفدية داخل السجل القياسي

معرف الخطر	الأصل المتأثر	التهديد / الثغرة	الخطر الكامن	الضوابط المطبقة	الخطر المتبقي	مالك الخطر
RSK-MAL-001	خوادم المبيعات وقواعد البيانات	تصيد احتيالي + ثغرة بنظام التشغيل	20 (حرج جداً)	تفعيل EDR + تدريب الوعي + النسخ الاحتياطي المعزول	6 (متوسط)	مدير أمن البنية التحتية

سيناريو -2 : خوادم بدون تحديثات أمنية (Unpatched)

استغلال الثغرات المعروفة في الأنظمة التي انتهى دعمها الفني

وصف الحالة

استمرار عمل تطبيقات قديمة على خادوم يعمل بنظام تشغيل غير مدعوم، مما يجعله عرضة لاستغلال ثغرات Zero-Day.

التهديد والثغرة

مخترق خارجي + حزم تحديث مفقودة (Missing Patches)

الخطر الكامن

احتمالية (5) × أثر (4) = 20 (حرج جداً)

الخطر المتبقي (بعد الضوابط)

احتمالية (2) × أثر (2) = 4 (منخفض)

تفريغ سيناريو -2 في سجل المخاطر

تسجيل خطة الترقية والعزل في السجل القياسي

معرف الخطر	الأصل المتأثر	التهديد / الثغرة	الخطر الكامن	الضوابط المطبقة	الخطر المتبقي	مالك الخطر
RSK-VUL-002	خادوم التطبيقات القديم (Legacy Server)	استغلال ثغرات معروفة + تأخر الترقية	**20 (حرج جداً)**	عزل الخادوم بشبكة وهمية VLAN + تطبيق الحماية الافتراضية vPatch	**4 (منخفض)**	رئيس قسم الأنظمة التشغيلية

سيناريو -3: تسريب بيانات عبر الموردين (Third-Party)

تحليل مخاطر سلاسل التوريد والوصول الخارجي للأنظمة

وصف الحالة

منح شركة صيانة خارجية صلاحيات وصول شاسعة بدون مصادقة متعددة العوامل، مما أدى لتعرض بيانات العملاء للكشف.

التهديد والثغرة

تسريب بيانات + صلاحيات خارجية مفرطة بدون مراقبة

الخطر الكامن

احتمالية (3) × أثر (5) = 15 (حرج)

الخطر المتبقي (بعد الضوابط)

احتمالية (1) × أثر (3) = 3 (منخفض)

تفريغ سيناريو -3: في سجل المخاطر

إدراج ضوابط إدارة مخاطر الأطراف الثالثة (TPRM)

معرف الخطر	الأصل المتأثر	التهديد / الثغرة	الخطر الكامن	الضوابط المطبقة	الخطر المتبقي	مالك الخطر
RSK-SUP-003	بيانات العملاء وحسابات الصيانة	اختراق المورد + ضعف تقييد الصلاحيات	15 (حرج)	تطبيق PAM + إلزامية MFA + توقيع اتفاقيات NDA وعقود صارمة	3 (منخفض)	مدير إدارة مخاطر الموردين

سيناريو -4: سوء إعدادات الحوسبة السحابية (Cloud)

انكشاف حاويات التخزين السحابي (S3 Buckets)للعامة

وصف الحالة

إنشاء حاوية تخزين سحابية جديدة تحتوي على نسخ احتياطية وتغيير إعدادات الإتاحة لتصبح "عامة" عن طريق الخطأ.

التهديد والثغرة

إنكشاف البيانات + خطأ بشري وسوء إعدادات الحساب

الخطر الكامن

احتمالية (4) × أثر (4) = 16 (حرج)

الخطر المتبقي (بعد الضوابط)

احتمالية (1) × أثر (2) = 2 (منخفض)

تفريغ سيناريو -4 في سجل المخاطر

توثيق ضوابط الأمان السحابي والمسح التلقائي

معرف الخطر	الأصل المتأثر	التهديد / الثغرة	الخطر الكامن	الضوابط المطبقة	الخطر المتبقي	مالك الخطر
RSK-CLD-004	حاوية التخزين السحابي (S3 Buckets)	خطأ إعدادات سحابي + وصول مباشر للإنترنت	16 (حرج)	تفعيل CSPM للمسح التلقائي + حظر الوصول العام بأسلوب الحظر المباشر	2 (منخفض)	مهندس أمن السحابة (Cloud Security)

لوحة سجل المخاطر المجمعة (Master Register)

نظرة شاملة لكافة سيناريوهات المحاضرة ومستويات الخطر المتبقي

ID	الأصل	الخطر الكامن	خطة المعالجة الأساسية	الخطر المتبقي	الحالة
RSK-MAL-001	قواعد بيانات المبيعات	20 (حرج جداً)	تطبيق نظام EDR وتدريب العاملين	6 (متوسط)	قيد التحديث
RSK-VUL-002	خادوم التطبيقات القديم	20 (حرج جداً)	عزل الشبكة وتطبيق الحماية الافتراضية	4 (منخفض)	مكتمل
RSK-SUP-003	حسابات الصيانة للموردين	15 (حرج)	إلزامية PAM وتطبيق المصادقة الثنائية	3 (منخفض)	مكتمل
RSK-CLD-004	الملفات السحابية المساندة	16 (حرج)	أتمتة أدوات CSPM وحظر الوصول العام	2 (منخفض)	مكتمل

أخطاء شائعة يجب تجنبها عند بناء السجل

تنبيهات أكاديمية لضمان سلامة وجودة السجل

1. الخلط بين الثغرة والتهديد

كتابة "عدم وجود MFA" كخطر، بينما هو في الواقع ثغرة تسهل إمكانية وقوع خطر "اختراق الحسابات".

2. تحويل السجل لوثيقة جامدة

تعبئة السجل مرة واحدة وحفظه دون مراجعة دورية أو ربطه بمؤشرات الأداء (KRI).

3. غياب مالك الخطر الفعلي

تعيين فريق الأمن السيبراني كمالك لجميع المخاطر، بدلاً من إسنادها لمالكي أصول الأعمال.

4. التقييم العشوائي دون معايير

إعطاء درجات الاحتمالية والأثر بناءً على الانطباع الشخصي دون الاستناد إلى المقاييس المحددة.

الملخص والواجب التطبيقي للأسبوع السابع

تكليف الطلاب لبناء سجل مخاطر مصغر

ملخص المحاضرة

سجل المخاطر هو أداة الحوكمة الرئيسية لنقل التهديدات التقنية إلى لغة أرقام وقرارات إدارية. نجاحه يعتمد على التحديد الدقيق، التقييم الموضوعي، والتابعية الواضحة لمالكي المخاطر.

الواجب العملي المطلوب

قم بإعداد جدول سجل مخاطر (Excel) متكامل يحتوي على **سيناريوهين جديدين** لمؤسسة صحية أو بنكية، مع تطبيق مصفوفة 5×5 وحساب الخطر الكامن والمتبقي واختيار الضوابط المناسبة.